

راهنمای کامل احراز هویت افزونه WordPress

قرارداد اتصال افزونه، مدیریت نصب‌ها از React، کپچای ورود و کنترل دسترسی
چندعاملی نصب

عوامل درخواست

JWT + Installation Key + Domain

نوع نشست

WORDPRESS

محافظت ورود

Rate Limit و CAPTCHA تطبیقی

مدیریت نصب

فقط از نشست WEB

۱. جمع‌آوری اطلاعات سایت

```
$site_url = home_url();
$site_name = get_bloginfo('name');
$metadata = [
    'wpVersion' => get_bloginfo('version'),
    'phpVersion' => PHP_VERSION,
    'pluginVersion' => DLANDER_PLUGIN_VERSION,
    'multisite' => is_multisite(),
];
```

فقط metadata غیرحساس ارسال شود. رمز دیتابیس، کلیدهای secret، wp-config.php و مسیرهای خصوصی سرور نباید ارسال شوند.

۲. ورود افزونه

```
POST /api/v1/auth/wordpress/login
Content-Type: application/json

{
  "email": "user@example.com",
  "password": "StrongPass123",
  "siteUrl": "https://shop.example.com",
  "siteName": "فروشگاه من",
  "metadata": {
    "wpVersion": "6.8",
    "phpVersion": "8.3",
    "pluginVersion": "1.0.0",
    "multisite": false
  }
}
```

پاسخ موفق:

```
{
  "data": {
    "accessToken": "WORDPRESS_ACCESS_TOKEN",
    "refreshToken": "WORDPRESS_REFRESH_TOKEN",
    "installationKey": "RANDOM_INSTALLATION_KEY",
    "site": {
      "id": "site-uuid",
      "domain": "shop.example.com",
      "enabled": true
    },
    "user": {
      "id": "user-uuid",
      "email": "user@example.com",
      "role": "USER",
      "status": "ACTIVE"
    }
  },
  "meta": null
}
```

دامنه normalize می‌شود؛ URL‌های دارای مسیر، حروف بزرگ و پروتکل متفاوت همگی به hostname پایدار مانند `shop.example.com` تبدیل می‌شوند.

۳. ذخیره امن اطلاعات در افزونه

```
update_option('dlander_access_token', $access_token, false);
update_option('dlander_refresh_token', $refresh_token, false);
update_option('dlander_installation_key', $installation_key, false);
update_option('dlander_site_id', $site_id, false);
```

WordPress Options معمولاً رمزنگاری‌شده نیست. در صورت امکان installation key و refresh token در `wp-config.php` یا `secret` storage هاست نگهداری شوند.

۴. درخواست‌های محافظت‌شده افزونه

تمام درخواست‌ها باید هر سه هدر زیر را داشته باشند:

```
Authorization: Bearer WORDPRESS_ACCESS_TOKEN
X-Dlander-Installation-Key: RANDOM_INSTALLATION_KEY
X-Dlander-Site-Url: https://shop.example.com
```

```
$response = wp_remote_get(
    DLANDER_API_URL . '/api/v1/users/me',
    [
        'timeout' => 20,
        'headers' => [
            'Authorization' => 'Bearer ' . $access_token,
            'X-Dlander-Installation-Key' => $installation_key,
            'X-Dlander-Site-Url' => home_url(),
            'Accept' => 'application/json',
        ],
    ],
);
```

اشتباه بودن توکن، کلید نصب، دامنه، وضعیت سایت، نشست یا حساب کاربری باعث پاسخ 401 می‌شود.

۵. تمدید توکن افزونه

```
POST /api/v1/auth/refresh
X-Dlander-Installation-Key: RANDOM_INSTALLATION_KEY
X-Dlander-Site-Url: https://shop.example.com
Content-Type: application/json

{ "refreshToken": "WORDPRESS_REFRESH_TOKEN" }
```

```
$response = wp_remote_post(
    DLANDER_API_URL . '/api/v1/auth/refresh',
    [
        'timeout' => 20,
        'headers' => [
            'Content-Type' => 'application/json',
            'X-Dlander-Installation-Key' => $installation_key,
            'X-Dlander-Site-Url' => home_url(),
        ],
        'body' => wp_json_encode([
            'refreshToken' => $refresh_token,
        ]),
    ],
);
```

افزونه باید access token و refresh token جدید را بلافاصله جایگزین مقادیر قبلی کند.

۶. کپچا در ورود WordPress

بعد از دومین رمز اشتباه، پاسخ دارای `CAPTCHA_REQUIRED` و `captchaRequired: true` است. افزونه باید با ایمیل کاربر از endpoint زیر تصویر بگیرد:

```
POST /api/v1/auth/captcha
Content-Type: application/json

{ "email": "user@example.com" }
```

سپس تصویر را در صفحه تنظیمات نمایش دهد و ورود را تکرار کند:

```
{
  "email": "user@example.com",
  "password": "StrongPass123",
  "siteUrl": "https://shop.example.com",
  "siteName": "فروشگاه من",
  "captchaId": "captcha-uuid",
  "captchaCode": "7K9P2",
  "metadata": {
    "wpVersion": "6.8",
    "phpVersion": "8.3",
    "pluginVersion": "1.0.0"
  }
}
```

۷. مدیریت سایت‌های WordPress از React

این endpointها فقط با access token نشست WEB قابل استفاده‌اند و نشست WordPress اجازه تغییر آنها را ندارد.

Endpoint	عملیات
GET /api/v1/users/me/wordpress-sites	فهرست نصب‌ها
POST /api/v1/users/me/wordpress-sites	ایجاد نصب
PATCH /api/v1/users/me/wordpress-sites/:id	ویرایش دامنه/نام/وضعیت
DELETE /api/v1/users/me/wordpress-sites/:id	حذف نصب
POST /api/v1/users/me/wordpress-sites/:id/rotate-key	تعویض کلید

ایجاد

```
{ "domain": "shop.example.com", "name": "فروشگاه اصلی" }
```

ویرایش یا غیرفعال‌سازی

```
{
  "domain": "new-shop.example.com",
  "name": "فروشگاه جدید",
  "enabled": true
}
```

```
{ "enabled": false }
```

تعویض کلید

```
POST /api/v1/users/me/wordpress-sites/SITE_UUID/rotate-key
Authorization: Bearer WEB_ACCESS_TOKEN
```

کلید جدید فقط در همین پاسخ نشان داده می‌شود. پس از تعویض، افزونه باید با کلید جدید تنظیم یا دوباره login شود.

۸. امنیت اعمال شده برای WordPress

مدل امنیتی: نشست JWT + WORDPRESS + کلید تصادفی نصب + تطبیق دامنه + کنترل فعال بودن نصب + refresh rotation + CAPTCHA.

نشست مستقل و اتصال به نصب

نشست افزونه با نوع WORDPRESS ثبت و به رکورد مشخص WordPressSite متصل می‌شود. این رکورد مالک، دامنه، هاش کلید نصب، metadata، وضعیت و آخرین اتصال را نگهداری می‌کند.

محافظت در صورت افشای JWT

JWT + Installation Key + Matching Domain

داشتن access token یا refresh token به تنهایی کافی نیست. کلید نصب عامل دوم است. دامنه secret نیست و هدر آن قابل جعل است؛ بنابراین دامنه به تنهایی عامل امنیتی محسوب نمی‌شود.

ذخیره و چرخش کلید

در بک‌اند فقط هاش SHA-256 کلید نصب ذخیره می‌شود. مقدار خام فقط هنگام ایجاد سایت، ورود افزونه یا rotate-key بازگردانده می‌شود.

ابطال فوری نشست‌ها

- تغییر دامنه، غیرفعال کردن یا حذف سایت از React
- تعویض installation key یا ورود مجدد افزونه
- logout، logout-all، مسدود یا حذف شدن حساب

جداسازی Control Plane

توکن WordPress نمی‌تواند تنظیمات WordPressSite را تغییر دهد. مدیریت نصب‌ها فقط از نشست WEB انجام می‌شود؛ بنابراین افزونه قادر نیست محدودیت دامنه یا وضعیت خودش را دور بزند.

محدودیت امنیتی

اگر مهاجم هم‌زمان installation key، refresh token، access token و site URL را به دست آورد، تا زمان ابطال نشست می‌تواند خود را افزونه معرفی کند. کاربر باید سایت را غیرفعال یا حذف کند، کلید را بچرخاند یا logout-all انجام دهد. لایه پیشرفته‌تر آینده می‌تواند nonce، HMAC و محافظت replay برای هر درخواست باشد.